

Security Scan Report

Target: <https://juice-shop.herokuapp.com/#/>

Scan Date: July 24, 2026 at 03:00 UTC

Scan ID: 0b92b6ee-1e07-4f86-9679-d7f7e10fd3bb

0 CRITICAL

3 HIGH

4 MEDIUM

9 LOW

Executive Summary

Security scan of 'https://juice-shop.herokuapp.com/#!/' identified 18 raw findings, reduced to 16 unique issues after deduplication. ■ 3 HIGH-severity issue(s) should be prioritized for remediation within the next 48 hours. 4 MEDIUM-priority issue(s) should be addressed in the current development sprint. 9 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	18
After Deduplication	16
Critical Findings	0
High Findings	3
Medium Findings	4
Low Findings	9
Scan Duration	145.1s

Detailed Findings

[HIGH] #1: Missing Auth in admin:0

Risk Score	0.6839
Affected Location	https://juice-shop.herokuapp.com/admin:0
Vulnerability Type	MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation

This endpoint or function lacks authentication, allowing unauthenticated users to access protected resources. Found in admin. Admin panel may be accessible without proper authentication.

Code or HTTP Excerpt

```
1 | GET /admin → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Unauthenticated users could access the admin panel, potentially viewing or modifying sensitive data without authorization.

Fix Recommendation

Rule-based recommendation: Add authentication middleware or decorators to all sensitive endpoints. Verify user identity before serving protected data.

[HIGH] #2: Information Disclosure in .env:0

Risk Score	0.5335
Affected Location	https://juice-shop.herokuapp.com/.env:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in .env. Exposed.

Code or HTTP Excerpt

```
1 | GET /.env → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
```

```
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed API keys helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Block access to .env files in your web server config. In nginx: location ~ /\.env { deny all; }. In Apache: <FilesMatch "\.env"> Require all denied </FilesMatch>.

[MEDIUM] #3: Cors Misconfiguration in crossdomain.xml:0

Risk Score	0.4850
Affected Location	https://juice-shop.herokuapp.com/crossdomain.xml:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The CORS policy is overly permissive, allowing unauthorized websites to make authenticated requests on behalf of users. Found in crossdomain.xml. crossdomain.

Code or HTTP Excerpt

```
1 | GET /crossdomain.xml → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

A malicious website could read API responses on behalf of authenticated users, potentially accessing sensitive data.

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains. Never combine wildcard origins with Allow-Credentials: true.

[MEDIUM] #4: Information Disclosure in config:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/.git/config:0
Vulnerability Type	INFORMATION_DISCLOSURE

CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in config. Exposed.

Code or HTTP Excerpt

```
1 | GET /.git/config → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed Git repository metadata and history helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Block access to .git/ directory in your web server config. In nginx: location ~ /\.git { deny all; }. Remove the .git directory from the deployed artifact.

[HIGH] #5: Information Disclosure in backup.sql:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/backup.sql:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-530
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in backup.sql. Database backup file is publicly accessible — critical data exposure.

Code or HTTP Excerpt

```
1 | GET /backup.sql → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed the database helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove database backup files from the web root. Store backups in a non-web-accessible directory. Add rules to deny access to *.sql, *.bak, *.dump file extensions.

[MEDIUM] #6: Information Disclosure in :0

Risk Score	0.4220
Affected Location	https://juice-shop.herokuapp.com/wp-admin/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing sensitive information that could help attackers plan targeted attacks. Found in . WordPress admin panel is publicly accessible.

Code or HTTP Excerpt

```
1 | GET /wp-admin/ → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact
The disclosed the admin panel helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation
Rule-based recommendation: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #7: Cors Misconfiguration in :0

Risk Score	0.3588
Affected Location	https://juice-shop.herokuapp.com/#!/:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation
The CORS policy is overly permissive, allowing unauthorized websites to make authenticated requests on behalf of users. Found in . CORS allows all origins (*).

Code or HTTP Excerpt

```
1 | Access-Control-Allow-Origin: *
```

Business Impact

A malicious website could read API responses on behalf of authenticated users, potentially accessing sensitive data.

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains. Never combine wildcard origins with Allow-Credentials: true.

[LOW] #8: Information Disclosure in phpinfo.php:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/phpinfo.php:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in phpinfo.php. PHP info page is publicly accessible — exposes server configuration details.

Code or HTTP Excerpt

```
1 | GET /phpinfo.php → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed configuration files helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Suppress the Server header version information. In nginx: server_tokens off; In Apache: ServerTokens Prod. In Flask: remove or override the Server header.

[LOW] #9: Information Disclosure in server-status:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/server-status:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in server-status. Apache server-status page is publicly accessible.

Code or HTTP Excerpt

```
1 | GET /server-status → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Suppress the Server header version information. In nginx: server_tokens off; In Apache: ServerTokens Prod. In Flask: remove or override the Server header.

[LOW] #10: Information Disclosure in debug:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/debug:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-215
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in debug. Debug endpoint is publicly accessible — may expose sensitive application internals.

Code or HTTP Excerpt

```
1 | GET /debug → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed internal network services helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #11: Information Disclosure in actuator:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/actuator:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in actuator. Spring Boot Actuator endpoints are publicly accessible.

Code or HTTP Excerpt

```
1 | GET /actuator → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[MEDIUM] #12: Information Disclosure in robots.txt:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in robots.txt. robots.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 28 bytes
3 | Preview: User-agent: *
4 | Disallow: /ftp
```

Business Impact

The disclosed user accounts and personal data helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Review robots.txt for sensitive path disclosure. While robots.txt is public, listing hidden paths like /admin or /backup reveals targets to attackers. Use authentication instead of obscurity.

[LOW] #13: Information Disclosure in sitemap.xml:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/sitemap.xml:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in sitemap.xml. sitemap.

Code or HTTP Excerpt

```
1 | GET /sitemap.xml → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed internal network services helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #14: Information Disclosure in .DS_Store:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/.DS_Store:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in .DS_Store. macOS.

Code or HTTP Excerpt

```
1 | GET /.DS_Store → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #15: Missing Security Header in :0

Risk Score	0.3168
Affected Location	https://juice-shop.herokuapp.com/#!/:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation

The server response is missing recommended HTTP security headers that instruct browsers to enable built-in protections. Found in . Missing HTTP Strict-Transport-Security (HSTS) header.

Code or HTTP Excerpt

```
1 | Response headers: Strict-Transport-Security = (not set)
```

Business Impact

Without this header, user accounts and personal data is more vulnerable to XSS, clickjacking, or MIME-type confusion attacks.

Fix Recommendation

Rule-based recommendation: Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS connections and prevent SSL stripping.

[LOW] #16: Information Disclosure in :0

Risk Score	0.2496
Affected Location	https://juice-shop.herokuapp.com/#!/:0

Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in . Missing Referrer-Policy header.

Code or HTTP Excerpt

```
1 | Response headers: Referrer-Policy = (not set)
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

Appendix

Deduplication Statistics

Total raw findings: 18 | After deduplication: 16 | Reduction: 11%

Scan Metadata

Scan ID	0b92b6ee-1e07-4f86-9679-d7f7e10fd3bb
Target	https://juice-shop.herokuapp.com/##
Timestamp	2026-07-24T03:00:09.665927+00:00
Duration	145.1s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "1a5fc985-4ef6-4349-986f-87a2efc09faf",
    "title": "Missing Auth in admin:0",
    "file": "https://juice-shop.herokuapp.com/admin",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "MISSING_AUTH",
    "description": "Admin panel may be accessible without proper authentication.",
    "rule_id": "sensitive-path-admin",
    "confidence": 0.85,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "GET /admin \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (
    \"sources\": [
      \"url-scanner\"
    ],
    \"risk_score\": 0.6839,
    \"risk_category\": \"HIGH\",
    \"category_source\": \"score\",
    \"category_reason\": \"score-threshold\",
    \"llm_explanation\": \"This endpoint or function lacks authentication, allowing unauthenticated users to ac
    \"fix_suggestion\": \"Add authentication middleware or decorators to all sensitive endpoints. Verify user :
    \"business_impact\": \"Unauthenticated users could access the admin panel, potentially viewing or modifying
    \"raw\": {
      \"url\": \"https://juice-shop.herokuapp.com/admin\",
      \"status\": 200,
      \"path\": \"/admin\"
    }
  },
  {
    \"id\": \"869cb4dc-75e6-4c64-8504-0cf7423bc750\",
    \"title\": \"Information Disclosure in .env:0\",
    \"file\": \"https://juice-shop.herokuapp.com/.env\",
    \"line_start\": 0,
    \"line_end\": null,
    \"severity\": \"HIGH\",
    \"vuln_type\": \"INFORMATION_DISCLOSURE\",
```

```

    "description": "Exposed .env file \u2014 may contain secrets, API keys, and database credentials.",
    "rule_id": "sensitive-path-.env",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /.env \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (c)
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5335,
    "risk_category": "HIGH",
    "category_source": "consistency_cache",
    "category_reason": "locked to historical category HIGH",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "Block access to .env files in your web server config. In nginx: location ~ /\\.env {
    "business_impact": "The disclosed API keys helps attackers identify attack vectors, reducing the effort
    "raw": {
        "url": "https://juice-shop.herokuapp.com/.env",
        "status": 200,
        "path": "/.env"
    }
},
{
    "id": "d343994b-0fcd-4ea2-8e1f-46d9a616b22e",
    "title": "Cors Misconfiguration in crossdomain.xml:0",
    "file": "https://juice-shop.herokuapp.com/crossdomain.xml",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "CORS_MISCONFIGURATION",
    "description": "crossdomain.xml found \u2014 may allow Flash-based cross-domain requests.",
    "rule_id": "sensitive-path-crossdomain.xml",
    "confidence": 0.85,
    "cwe_id": "CWE-942",
    "cvss_score": null,
    "code_snippet": "GET /crossdomain.xml \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ C
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.485,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The CORS policy is overly permissive, allowing unauthorized websites to make authent
    "fix_suggestion": "Restrict Access-Control-Allow-Origin to specific trusted domains. Never combine wildc
    "business_impact": "A malicious website could read API responses on behalf of authenticated users, poten
    "raw": {
        "url": "https://juice-shop.herokuapp.com/crossdomain.xml",
        "status": 200,
        "path": "/crossdomain.xml"
    }
},
{
    "id": "bfb9afef-fd69-4ae1-937d-7ff54d78f290",
    "title": "Information Disclosure in config:0",
    "file": "https://juice-shop.herokuapp.com/.git/config",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Exposed .git directory \u2014 source code and commit history are publicly accessible.",
    "rule_id": "sensitive-path-.git-config",
    "confidence": 0.85,
    "cwe_id": "CWE-538",
    "cvss_score": null,
    "code_snippet": "GET /.git/config \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyr
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.4462,
    "risk_category": "MEDIUM",

```

```

"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
"fix_suggestion": "Block access to .git/ directory in your web server config. In nginx: location ~ /\.\.",
"business_impact": "The disclosed Git repository metadata and history helps attackers identify attack vectors",
"raw": {
  "url": "https://juice-shop.herokuapp.com/.git/config",
  "status": 200,
  "path": "/.git/config"
}
},
{
  "id": "3f06c995-634d-4e68-8497-459f7601cc2b",
  "title": "Information Disclosure in backup.sql:0",
  "file": "https://juice-shop.herokuapp.com/backup.sql",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Database backup file is publicly accessible \u2014 critical data exposure.",
  "rule_id": "sensitive-path-backup.sql",
  "confidence": 0.85,
  "cwe_id": "CWE-530",
  "cvss_score": null,
  "code_snippet": "GET /backup.sql \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4462,
  "risk_category": "HIGH",
  "category_source": "consistency_cache",
  "category_reason": "locked to historical category HIGH",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "Remove database backup files from the web root. Store backups in a non-web-accessible",
  "business_impact": "The disclosed the database helps attackers identify attack vectors, reducing the eff",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/backup.sql",
    "status": 200,
    "path": "/backup.sql"
  }
},
{
  "id": "11b00d0c-5aab-4407-a698-8c8f565b2e34",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/wp-admin/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "WordPress admin panel is publicly accessible.",
  "rule_id": "sensitive-path-wp-admin",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /wp-admin/ \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.422,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version head",
  "business_impact": "The disclosed the admin panel helps attackers identify attack vectors, reducing the",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/wp-admin/",
    "status": 200,
    "path": "/wp-admin/"
  }
},

```

```

{
  "id": "2b6abfd4-f8be-47f4-a8d7-b1d2abb05ca5",
  "title": "Cors Misconfiguration in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "CORS_MISCONFIGURATION",
  "description": "CORS allows all origins (*). While credentials are not included, this may expose public",
  "rule_id": "cors-wildcard",
  "confidence": 0.6,
  "cwe_id": "CWE-942",
  "cvss_score": null,
  "code_snippet": "Access-Control-Allow-Origin: *",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3588,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The CORS policy is overly permissive, allowing unauthorized websites to make authentic",
  "fix_suggestion": "Restrict Access-Control-Allow-Origin to specific trusted domains. Never combine wildc",
  "business_impact": "A malicious website could read API responses on behalf of authenticated users, poten",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "acao": "*"
  }
},
{
  "id": "19399449-39c4-43f9-9a51-e0ee3eb6127b",
  "title": "Information Disclosure in phpinfo.php:0",
  "file": "https://juice-shop.herokuapp.com/phpinfo.php",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "PHP info page is publicly accessible \u2014 exposes server configuration details.",
  "rule_id": "sensitive-path-phpinfo.php",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /phpinfo.php \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyr",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "Suppress the Server header version information. In nginx: server_tokens off; In Apache",
  "business_impact": "The disclosed configuration files helps attackers identify attack vectors, reducing",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/phpinfo.php",
    "status": 200,
    "path": "/phpinfo.php"
  }
},
{
  "id": "71389280-62c1-43f0-a3d6-8196a5dd2902",
  "title": "Information Disclosure in server-status:0",
  "file": "https://juice-shop.herokuapp.com/server-status",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Apache server-status page is publicly accessible.",
  "rule_id": "sensitive-path-server-status",
  "confidence": 0.85,
  "cwe_id": "CWE-200",

```

```

"cvss_score": null,
"code_snippet": "GET /server-status \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copy
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
"fix_suggestion": "Suppress the Server header version information. In nginx: server_tokens off; In Apache
"business_impact": "The disclosed server configuration details helps attackers identify attack vectors,
"raw": {
  "url": "https://juice-shop.herokuapp.com/server-status",
  "status": 200,
  "path": "/server-status"
}
},
{
  "id": "5474886f-819d-4e1a-b2b4-9ad01856e777",
  "title": "Information Disclosure in debug:0",
  "file": "https://juice-shop.herokuapp.com/debug",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Debug endpoint is publicly accessible \u2014 may expose sensitive application internals
  "rule_id": "sensitive-path-debug",
  "confidence": 0.85,
  "cwe_id": "CWE-215",
  "cvss_score": null,
  "code_snippet": "GET /debug \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (C
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
  "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version head
  "business_impact": "The disclosed internal network services helps attackers identify attack vectors, red
  "raw": {
    "url": "https://juice-shop.herokuapp.com/debug",
    "status": 200,
    "path": "/debug"
  }
},
{
  "id": "8b8891b2-9344-414a-a403-caf5b7db851e",
  "title": "Information Disclosure in actuator:0",
  "file": "https://juice-shop.herokuapp.com/actuator",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Spring Boot Actuator endpoints are publicly accessible.",
  "rule_id": "sensitive-path-actuator",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /actuator \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
  "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version head

```

```

    "business_impact": "The disclosed server configuration details helps attackers identify attack vectors,
    "raw": {
      "url": "https://juice-shop.herokuapp.com/actuator",
      "status": 200,
      "path": "/actuator"
    }
  },
  {
    "id": "c8fe4087-df33-4cd3-9d66-e601c261d40b",
    "title": "Information Disclosure in robots.txt:0",
    "file": "https://juice-shop.herokuapp.com/robots.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "robots.txt may reveal hidden paths and sensitive directories.",
    "rule_id": "sensitive-path-robots.txt",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 28 bytes\nPreview: User-agent: *\nDis
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "MEDIUM",
    "category_source": "consistency_cache",
    "category_reason": "locked to historical category MEDIUM",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "Review robots.txt for sensitive path disclosure. While robots.txt is public, listing
    "business_impact": "The disclosed user accounts and personal data helps attackers identify attack vectors,
    "raw": {
      "url": "https://juice-shop.herokuapp.com/robots.txt",
      "status": 200,
      "path": "/robots.txt"
    }
  },
  {
    "id": "f149e7d3-949f-4f21-82c5-13e5d871c5a1",
    "title": "Information Disclosure in sitemap.xml:0",
    "file": "https://juice-shop.herokuapp.com/sitemap.xml",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "sitemap.xml may reveal internal URL structure.",
    "rule_id": "sensitive-path-sitemap.xml",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /sitemap.xml \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyr
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version head
    "business_impact": "The disclosed internal network services helps attackers identify attack vectors, re
    "raw": {
      "url": "https://juice-shop.herokuapp.com/sitemap.xml",
      "status": 200,
      "path": "/sitemap.xml"
    }
  },
  {
    "id": "9cf0dc6e-42ea-483b-937e-f6873ae323c9",
    "title": "Information Disclosure in .DS_Store:0",
    "file": "https://juice-shop.herokuapp.com/.DS_Store",

```

```

"line_start": 0,
"line_end": null,
"severity": "MEDIUM",
"vuln_type": "INFORMATION_DISCLOSURE",
"description": "macOS .DS_Store file is publicly accessible \u2014 may reveal directory structure.",
"rule_id": "sensitive-path-.DS_Store",
"confidence": 0.85,
"cwe_id": "CWE-538",
"cvss_score": null,
"code_snippet": "GET /.DS_Store \u2019 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
"fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version head
"business_impact": "The disclosed server configuration details helps attackers identify attack vectors,
"raw": {
  "url": "https://juice-shop.herokuapp.com/.DS_Store",
  "status": 200,
  "path": "/.DS_Store"
}
},
{
  "id": "138df147-65d3-432f-bf39-dd3b105b6b94",
  "title": "Missing Security Header in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "MISSING_SECURITY_HEADER",
  "description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow
  "rule_id": "header-missing-strict-transport-security",
  "confidence": 0.95,
  "cwe_id": "CWE-319",
  "cvss_score": null,
  "code_snippet": "Response headers: Strict-Transport-Security = (not set)",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3168,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server response is missing recommended HTTP security headers that instruct brow
  "fix_suggestion": "Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS con
  "business_impact": "Without this header, user accounts and personal data is more vulnerable to XSS, cli
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "header": "Strict-Transport-Security",
    "check": "missing_header"
  }
},
{
  "id": "5ccd26a9-49ea-4612-8ced-cd74f7727c36",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Missing Referrer-Policy header. Sensitive information in URLs may be leaked to third-par
  "rule_id": "header-missing-referrer-policy",
  "confidence": 0.8,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "Response headers: Referrer-Policy = (not set)",
  "sources": [

```

```
    "url-scanner"  
  ],  
  "risk_score": 0.2496,  
  "risk_category": "LOW",  
  "category_source": "score",  
  "category_reason": "score-threshold",  
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted attacks.",  
  "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version headers.",  
  "business_impact": "The disclosed server configuration details helps attackers identify attack vectors, such as exploiting known vulnerabilities or performing brute force attacks.",  
  "raw": {  
    "url": "https://juice-shop.herokuapp.com/#/",  
    "header": "Referrer-Policy",  
    "check": "missing_header"  
  }  
}  
]
```